

STANDARDIZED OPSEC PLAYBOOK

DoD OPSEC process + NIST controls + 0day Ryan Montgomery field tips

Refs: DoDD 5205.02E | NIST 800-53r5, 800-171/CMMC 2.0, CSF 2.0, CISA | 0day: pentester.com @0dayCTF

W1D0WM4K3R // B1SCU1TK1D.com

November 3, 2026 - free to share; standard practice, no secrets inside

WHAT OPSEC IS - AND WHY IT IS A PROCESS

- **Definition:** Operations Security (OPSEC) is a systematic process that denies adversaries information about capabilities and intentions. DoD defines it as the analytical process used to identify critical information, assess threats and vulnerabilities, and apply countermeasures to protect that information.
- **The five steps:** 1) Identify critical information. 2) Analyze the threat. 3) Analyze vulnerabilities. 4) Assess risk. 5) Apply countermeasures. Then repeat - OPSEC is a cycle, not a checklist you finish.
- **Why a standard:** Small companies skip OPSEC because it sounds military. Adversaries count on that. This playbook is the standard for every team member - the government framework gives it teeth, the 0day tips make it stick.

STEP 1 - IDENTIFY CRITICAL INFORMATION

- **Definition:** Critical information is anything an adversary could use to damage us, our clients, or our contracts if they learned it. If you cannot explain who is hurt by a piece of information getting out, it is not critical. If you can, it is - and it gets protected.
- **The list:** Proprietary methods and tooling. Model weights and training data. Client names and site locations. Operational schedules and test results. Pricing and margins. Personnel roles and travel. Any contract or compliance details.
- **The rule:** Default-denied for the list above. If sharing it has no mission value, it does not get shared.

STEP 2 - ANALYZE THE THREAT

- **State actors:** Foreign intelligence targets technical teams through fake recruiters, fake RFPs, and spearphish. The TraderTraitor playbook (the Binance heist) and the fake-RFP probes that hit contact forms everywhere this year are the same species: a well-timed lure with a payload behind it.
- **Competitors:** Recon is legal and constant. Rivals will read your posts, map your team, and price against you. What you publish is their market intel.
- **Criminals:** Business email compromise (BEC) is the highest-dollar cyber crime. The goal: impersonate a trusted party and redirect money or data. The only defense is verification habits.
- **The insider:** The most common leak is not malicious - it is a teammate being helpful. 'Where are you flying this week?' deserves the same discipline as a foreign approach.

STEP 3 - ANALYZE VULNERABILITIES

- **The OSINT reality:** 0day Ryan Montgomery's DEF CON demo: from a name and ONE phone number, he pulled the subject's full history of addresses and numbers in minutes. That is the baseline. Everything public about you is one query away from an adversary.
- **Our exposure:** LinkedIn org charts, geotagged site photos, conference posts, personal social accounts tied to company email, reused credentials, unpatched devices, unencrypted chat, badge photos.
- **The test:** Search yourself like an adversary would: name, phone, email, address. Whatever you find, they found first. Remove it or own it - nothing in between.

STEP 4 - ASSESS RISK

- **The matrix:** Risk = likelihood x impact. High-likelihood + high-impact (credential reuse, unverified email attachments) = treat as non-negotiable. Low-likelihood + low-impact (a conference selfie with no site context) = accept, but do not repeat.
- **The stance:** Mitigate what is cheap to mitigate, avoid what is irreversible, accept only what is truly harmless. Every control below is a mitigation - they are priced in hours, not dollars.

STEP 5 - COUNTERMEASURES (GOVERNMENT STANDARD + 0DAY TIPS)

Use a password manager. Unique, random 16+ character password for every account. No memorized passwords, no reuse.

NIST 800-53: IA-5(1), IA-5(5)
CMMC 2.0: IA.2.078, IA.2.079
0DAY: Use the password manager - his #1 published tip. Reuse is the #1 root cause of breaches.

Multi-factor authentication everywhere - email, repos, cloud, banking. Phishing-resistant (FIDO2/hardware key) for anything critical.

NIST 800-53: IA-2(1)
CMMC 2.0: IA.2.081
0DAY: 2FA on every account you own, without exception.

Recognize and report phishing. Never open unexpected attachments, never enable macros, verify the sender domain - not the display name.

NIST 800-53: AT-2(2), SI-3
CMMC 2.0: AT.2.056, SI.2.083
0DAY: Stop clicking random links and opening email attachments - the exact words his audience summarizes.

Keep devices patched and protected. Updates within days. Endpoint protection installed and current.

NIST 800-53: SI-2, SI-3
CMMC 2.0: SI.2.082
0DAY: Install an antivirus and keep it updated.

Freeze your credit - personal AND family - at Equifax, Experian, and TransUnion. Thaw only when you need credit.

NIST 800-53: PS-4, IA-8 (identity protection)
CMMC 2.0: PS.2.128
0DAY: His signature move: 'ACCESS FILES WITH A CREDIT CARD (no password)' - he demonstrates it on camera and tells you to do it for friends and family too.

Minimize public data. Opt out of data brokers, use burner email for signups, Google yourself quarterly, and remove what you find.

NIST 800-53: PT-3, PT-7 (privacy)

CMMC 2.0: N/A (best practice)

0DAY: His OSINT demos exist to teach one thing: name + phone = your whole history. Minimize the seed data.

Social media discipline: no travel plans, no badges, no client sites, no org charts, no kids' school details.

NIST 800-53: AT-3 (role-based training)

CMMC 2.0: AT.2.057

0DAY: Privacy settings on everything; do not post identifying or location data - especially anything involving family.

Physical security: RFID-blocking wallet, badge out of sight off-site, clean desk, lock screens on every device.

NIST 800-53: PE-3, PE-5

CMMC 2.0: PE.2.134, PE.2.135

0DAY: Use an RFID-blocking wallet - contactless card skimming is trivial and silent.

Safe browsing and downloads: heed browser warnings, no cracked software, no work on shared/personal devices.

NIST 800-53: SI-3, CM-7 (least functionality)

CMMC 2.0: CM.2.062

0DAY: Be careful with the websites you are visiting - if the browser warns, leave.

Monitor for exposure: breach notifications, dark-web checks on company domains, immediate response when a service reports a leak.

NIST 800-53: SI-4 (monitoring)

CMMC 2.0: SI.2.081

0DAY: He built Pentester.com around breach detection - check your accounts and your family's against known breaches.

RESPOND - WHEN SOMETHING SLIPS (NIST CSF 2.0)

- **Detect:** Report immediately to the security POC. Speed beats shame - a fast report of a near-miss is a win, a slow report of a hit is a firing offense.
- **Respond:** Disconnect the device, change credentials from a clean machine, preserve the email/attachment for forensics - do not delete evidence.
- **Recover:** Assume email compromise until proven otherwise. Notify affected parties when facts are known. Over-notify early; explain late is worse.

COMPLIANCE NOTE (CMMC 2.0)

- **Why it matters:** DoD contracts carrying CUI require CMMC 2.0 Level 2 - the 110 practices of NIST SP 800-171. Awareness, training, access control, and media protection practices are audited. This playbook operationalizes them as habits, which is exactly how small companies pass.
- **The line:** Level 3 adds NIST SP 800-172 controls for critical programs. When a contract demands it, we build to it. This playbook is the floor, not the ceiling.

QUICK-REFERENCE CARD - PRINT AND POST

- **1:** Password manager + unique passwords. No reuse. Ever.
- **2:** MFA on everything. FIDO2 where it counts.
- **3:** Never open unexpected attachments. Never enable macros.
- **4:** Verify the domain, not the display name.
- **5:** Money and data changes: confirm by second channel. Always.
- **6:** Updates within days. Antivirus on. RFID wallet in pocket.
- **7:** Credit frozen at all three bureaus - you and your family.
- **8:** No travel plans, badges, sites, or org charts on social.
- **9:** Google yourself quarterly. Remove what you find.
- **10:** Slipped? Report in hour zero. Speed beats shame.